

Security

CSC week 5

Propedeuse periode A

Security



Disclaimer gebruikte materialen

- Er wordt veel gebruik gemaakt van plaatjes van diverse internetbronnen om onderwerpen duidelijker te maken. Niet overal is de bron vermeld. Waar dat kan, wordt gebruik gemaakt van Open Access/Open Source.
- Daarnaast is er veel materiaal zelf gemaakt.
- Deze slides zijn alleen voor intern gebruik bij de Hogeschool Utrecht.

Bespreken oefentoets

TestVision Toets TICT_V1IPMC-22_CSC_Oefentoets - Werk - Microsoft Edge

https://hu.testvision.nl/online/fe/afname_toets.htm?idstr=1695897699017&skin=10

TICT_V1IPMC-22_CSC_Oefentoets

david.vermeulen@hu.nl
David Vermeulen

ID: 394875 1 punt

Zet op volgorde hoe een switch werkt.



Antwoordvak

☐ PC1 kan communiceren met PC2

☐ PC1 wil communiceren met PC2

☐ Van de poort van PC1 wordt er een directe verbinding gelegd met de poort van PC2

☐ De switch zoekt waar PC2 zich bevindt

Help Instructie Tijd 00:59

Vraag 2 / 20

Overzicht Klaar Vorige Volgende

Herhaling & Bespreken Oefening CSC4.3

Oefening CSC4.3: Directories en bestanden

```
david@ubuntusemester1-001: ~  
Expanded Security Maintenance for Applications is not enabled.  
  
0 updates can be applied immediately.  
  
Enable ESM Apps to receive additional future security updates.  
See https://ubuntu.com/esm or run: sudo pro status  
  
Last login: Thu Aug 31 13:33:55 2023 from 80.115.91.72  
david@ubuntusemester1-001:~$ tree  
.  
├── Vermeulen  
│   └── David  
│       ├── Hobbies  
│       │   ├── BeachVolleybal  
│       │   ├── Suppen  
│       │   └── Volleybal  
│       │       └── heren4.txt  
│       └── Werk  
│           ├── Architect  
│           └── HU-Docent  
└── tree.txt  
  
9 directories, 2 files  
david@ubuntusemester1-001:~$
```

Waarom security? Wat beveiligen we?

Privégegevens personeel Hogeschool Utrecht op darkweb na hack

20 oktober 2022, 18:11 • 1 minuut leestijd



© Pixabay

Utrecht - Na een hack bij het bedrijf ID-ware zijn personeelsgegevens van de Hogeschool Utrecht gestolen en op het darkweb geplaatst. Het gaat om een onbekend aantal namen, personeelsnummers en zelfs woonadressen.

DTC: niet c Hackers zeggen gegevens van 560 r klanten Ticketmaster in handen te k

22 mei 2023



Een groep hackers zegt dat het de persoonlijke gegevens van Ticketmaster in handen heeft. De groep zegt adressen, mailadressen, telefoonnummers, creditcardgegevens, ticketaankopen van klanten te hebben gestolen.

De hackersgroep, genaamd ShinyHunters, heeft bewijs darkweb geplaatst. Naar verluidt zijn de gegevens te koop (463.000 euro) als "eenmalige aanbieding". Ook eist de gegevens niet vrij te geven.

Ticketmaster heeft veel klanten in Australië. De Australische overheid is hoogte te zijn van het incident en de zaak met Ticketmaster. Amerikaanse FBI heeft daarbij volgens een woordvoerder ambassade hulp aangeboden.

Ticketmaster heeft nog niet gereageerd op de hack. Het is niet bekend of data van Nederlandse klanten gestolen zijn.

Dat blijkt uit onderzoek van het Digital Trust Center (DTC). Het onderzoek naar de weerbaarheid nog niet overal op orde is, komt doordat basisgegevens niet voldoende doorgevoerd worden. Het DTC doelt hiermee op twee stappen en het maken en testen van back-ups.



vast vrijdag 24 mei, 18:08

end succesvol bij na'

Ellen Kamphorst

redacteur Binnenland



23 flink

o klanten van onlinebank Bunq, vaak tienduizenden euro's weten buit te halen en [NRC](#).

e aanvallers waarschijnlijk geen schade van de buitgemaakte bedragen die andere banken wel hebben niet gecompenseerd.

... van de gegevens van de medewerkers met

Security





NOS Nieuws • Vandaag, 05:04 • Aangepast vandaag, 14:20



Bunq komt alsnog met schadevergoeding voor fraudeslachtoffers

Fraudeslachtoffers bij onlinebank Bunq krijgen alsnog een schadevergoeding. De bank compenseerde tot nu toe niet. Eind mei bleek uit onderzoek van NOS en NRC dat klanten van Bunq grote bedragen verloren door online oplichting. Volgens experts had de werkwijze van de aanvallers waarschijnlijk geen succes bij andere banken, en ook de hoogte van de buitgemaakte bedragen wekte verbazing.

Waarom security?

Gevoelige informatie

- Privacy-gevoelige informatie.
- Niet-openbare informatie

Ongeoorloofd inzage en gebruik

- Geen rechten
- Geen noodzaak

NOS Nieuws

donderdag 5 april 2018, 07:32

Aangepast donderdag 5 april 2018, 14:35

Tientallen onbevoegden bekeken medisch dossier Barbie

Tientallen medewerkers van het Haga-ziekenhuis in Den Haag hebben volgens een klokkenluider ongeoorloofd het medische dossier bekeken van realityster Samantha de Jong, beter bekend als Barbie.

Voorkomen van ongeoorloofde toegang en gebruik van gegevens!

Wat beveiligen we?

I(C)T: Informatie (en Communicatie) Technologie:

- Draait om informatie en data
- De beveiliging doormiddel van verschillende technieken

Hoe beveiligen we de data?

- Veilige processen
 - Veilige software
 - Veilig omgang met systemen
 - Beveiligde Infrastructuur
- } Beveiligingsfocus CSC

Beveiligingsaspecten

Confidentiality: alleen toegankelijk voor ...

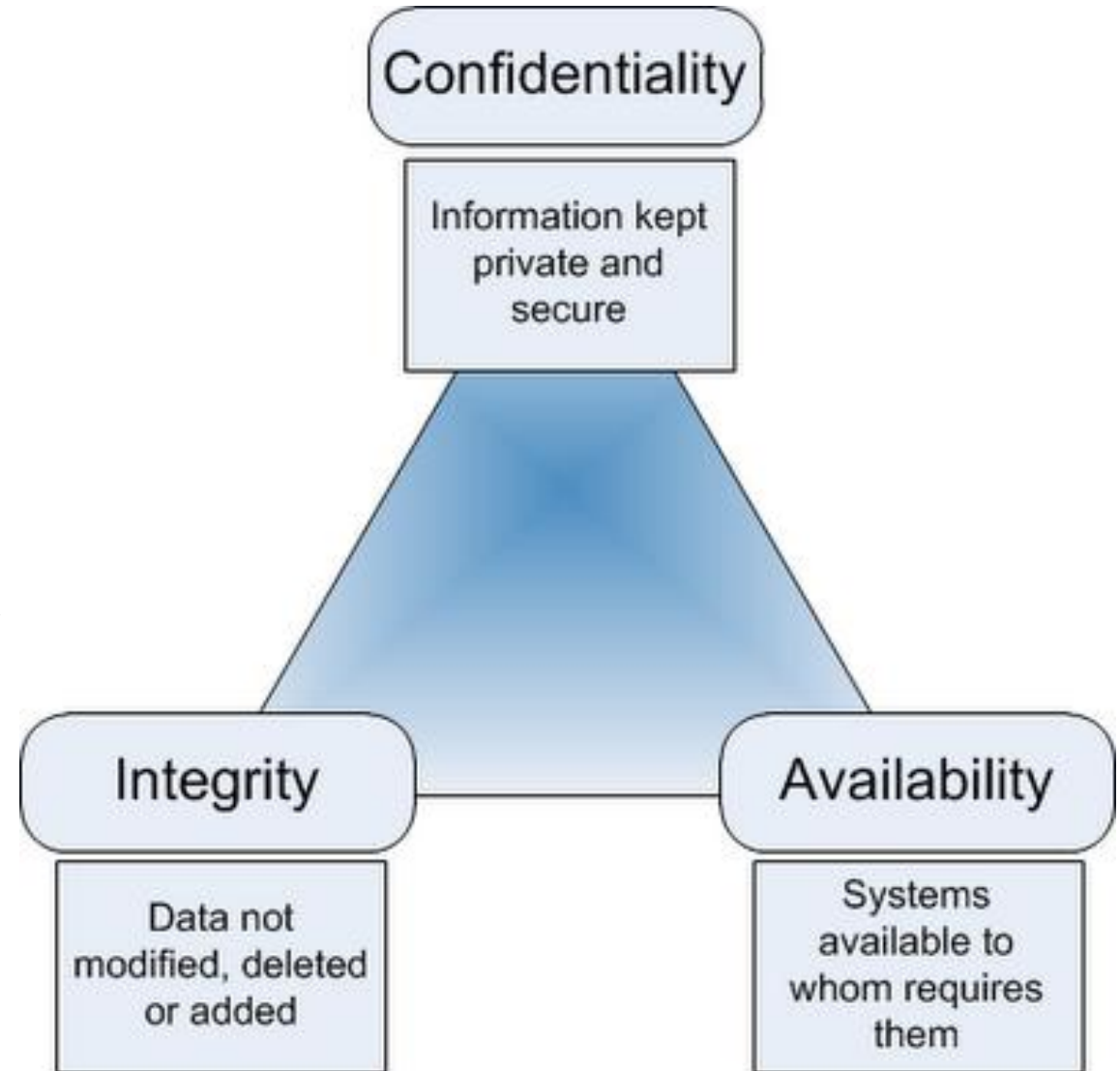
- “Vertrouwelijkheid”

Integrity: geen aanpassingen / verlies data

- “Integriteit”

Availability: is het systeem toegankelijk?

- “Beschikbaarheid”



Wat betekent dit concreet? Het 'hoe'

We willen dat de gevoelige informatie – wanneer deze ergens is opgeslagen maar ook wanneer deze van het ene naar het andere systeem onderweg is goed wordt beveiligd:

- **Confidentiality**

- Informatie alleen leesbaar is voor hen die daar gerechtigd of genoodzaakt toe hebben
- Hoe? -> Rechten instellen

- **Integrity**

- Informatie alleen aangepast worden door degenen die daartoe gerechtigd toe zijn
- Hoe? -> Digitaal onderteken en 'hash' bepalen

- **Availability**

- Informatie is benaderbaar wanneer daar een noodzaak toe is
- Hoe? -> Redundantie van informatie systemen

Veel voorkomende **technische aanvallen**:

- Onterechte rechten verkrijgen.
- Onderscheppen van berichten.
- Man-in-the-middle (als doorgeefluik berichten aanpassen)
- Distributed denial of service (**DDoS**) attack

Oefening CSC5.1: Wachtwoord sniffen

Oefening CSC5.1: Wachtwoord sniffen

Je gaat een wachtwoord sniffen door een ftp sessie af te luisteren

- Start Wireshark
- Filter op ftp
- Open een commandprompt / cmd / powershell
- Voer uit: **ftp <en dan naar het ip-adres dat de docent doorgeeft of je eigen server>**
- Voer als user in: je HU mailadres
- Voer als wachtwoord in: een willekeurige tekst
- Zie je je mailadres en wachtwoord langskomen?

ftp						
No.	Time	Source	Destination	Protocol	Length	Info
17432	553.1763...	20.4.11.136	192.168.68.101	FTP	74	Response: 220 (vsFTPd 3.0.5)
17433	553.1778...	192.168.68.101	20.4.11.136	FTP	68	Request: OPTS UTF8 ON
17435	553.1945...	20.4.11.136	192.168.68.101	FTP	80	Response: 200 Always in UTF8 mode.
17494	557.7964...	192.168.68.101	20.4.11.136	FTP	66	Request: USER david
17495	557.8152...	20.4.11.136	192.168.68.101	FTP	88	Response: 331 Please specify the password.
17502	559.3411...	192.168.68.101	20.4.11.136	FTP	65	Request: PASS piet
17544	562.2556...	20.4.11.136	192.168.68.101	FTP	76	Response: 530 Login incorrect.

Oefening CSC5.1+: FTP op je server zetten

Je hebt nu een FTP sessie opgezet naar de centrale server. Maar je kan ook FTP op je eigen virtuele server in Azure zetten:

- Start een ssh sessie naar je server
- Voer uit in SSH:
 - `sudo apt update && sudo apt upgrade`
 - `sudo apt install vsftpd`
- Zet de poort open via de Portal van Azure (portal.azure.com)
- Settings -> Networking
 - Source: My IP address
 - Source port: *
 - Destination: Any
 - Service: FTP
- Voer uit op je laptop: **ftp <ip adres van je server>**
- Zie je nu ook je eigen gegevens voorbij komen?

Bedreigingen

Hackers

- Personen die zonder toestemming misbruik willen maken van jouw system
- Verschillende aanpakken
 - Veel kennis (unieke aanpak)
 - Veel tools (standaard aanpak)
- Individuele hacker of onderdeel van een groep
- De meeste hackers willen er geld mee verdienen, soms script-kiddies.



Definitie volgens Wikipedia:

Een **hacker** verwijst vaak naar een persoon die binnendringt in een [computernetwerk](#) door de beveiliging te omzeilen (soms ook wel **kraker** of **cracker** genoemd).

Maar in de originele betekenis kan het ook verwijzen naar iemand die bestaande middelen gebruikt voor oplossingen te vinden voor problemen waarvoor dat middel niet oorspronkelijk bedoeld was, zoals deelnemers van een [hackathon](#) of door gebruik van [life hacks](#).

Ethical hacker

- Beveiligingsproblemen op sporen
- Met toestemming van de eigenaar!
- Systematisch netwerkinfrastructuren controleren
- Beveiligingsstatus door kwetsbaarheden in het netwerk- en systeeminfrastructuur te identificeren
- Ongeautoriseerde toegang mogelijk?



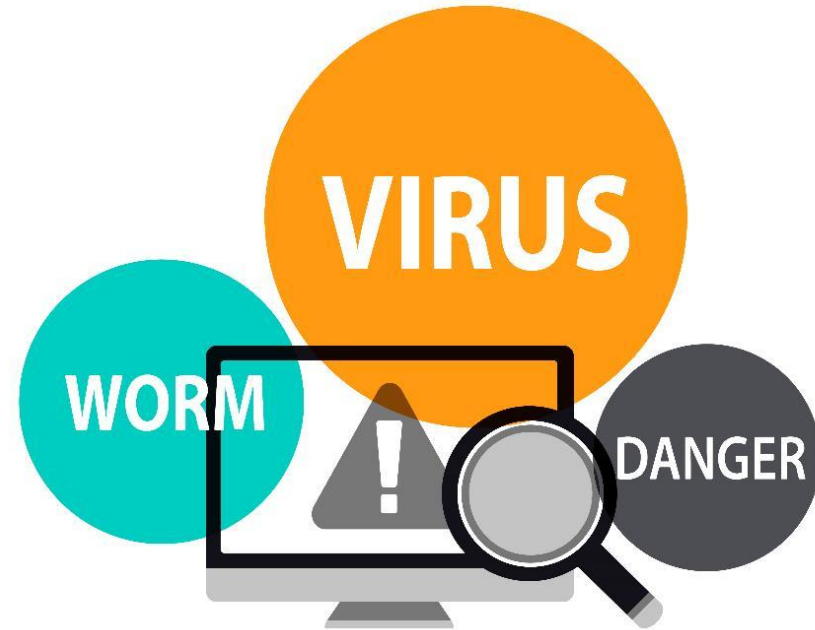
Definitie volgens Wikipedia:

Een **ethisch hacker** is een computerspecialist die beveiligingssystemen en netwerken test op een positieve manier. Zijn doel is om door middel van hacken fouten en veiligheidslekken op te sporen in de systemen en [netwerken](#) om deze daarna te melden aan de bedrijven of instanties waarmee ze samenwerken. Ze willen helpen in de strijd tegen [cybercriminaliteit](#). Het zijn de 'good guys' van het internet. De Engelse term voor ethisch hacken is *software/security vulnerability disclosure*.

Malware

Malicious software (Malware):

- Virussen
- Worm
- Spyware / adware
- Rootkit / Backdoor
- Ransomware



Definitie volgens Wikipedia:

Malware is elke [software](#) die gebruikt wordt om [computersystemen](#) te verstoren, gevoelige informatie te verzamelen of toegang te krijgen tot private computersystemen. Het woord is een samentrekking van het Engelse *malicious software* (kwaadaardige software, soms schadelijke software). Malware veronderstelt kwade opzet. Software waarmee geen kwaad wordt beoogd, valt hier dus niet onder.

Malware: ransomware

- **Malware**
 - Vaak verspreid via kwaadaardige websites, e-mails en software.
 - Vaak verborgen in andere bestanden, zoals afbeeldings- of documentbestanden, of zelfs in onschuldige uitziende bestanden, zoals .exe-bestanden.
- **Ransomware**
 - Ontworpen om een gebruiker of organisatie de toegang tot bestanden op hun computer te ontfeggen.
 - Doormiddel van bestanden te versleutelen en een losgeldbetaling te eisen voor de decryptiesleutel.

Tweakers.net - 5 februari 2020

Universiteit Maastricht betaalde 197.000 euro losgeld voor ransomwareaanval

De Universiteit Maastricht bevestigt dat het 197.000 euro aan losgeld betaalde na de ransomwareaanval waar de instelling vorig jaar door werd getroffen. Dat werd gedaan om de continuïteit van het onderwijs te garanderen.

Malware: virussen

Onder andere:

- **Bootsectorvirus**
 - gebonden aan opslagmedia
- **Macro-virus**
 - vooral in *office suite* bestanden
- **Trojan**
 - Vermomd als veilige normale software
- **Hoax**
 - schadelijk onzinverhaal



Een **Worm** is een speciaal virus. Dat verspreid zichzelf, door gaten in andere system op te zoeken.

Social engineering

De kunst van toegang krijgen tot data door mensen beveiligingsgegevens te ontfutselen

- **Pretexting**
 - babbeltrucs zoals oplichters die ook gebruiken
 - bijv. bellen namens een bank of verzekeraar
- **Phishing**
 - berichten (vaak via e-mail, SMS of WhatsApp) waarbij mensen worden verleid om gegevens prijs te geven

NOS Nieuws

dinsdag 8 november 2022, 18:40

Drie jaar cel voor phishing uit naam van de ANWB

Een 24-jarige man uit Amsterdam moet drie jaar de cel in voor het versturen van valse betalingsherinneringen. Hij stuurde de phishingmails tussen januari en april van dit jaar aan meer dan 10.000 leden van de ANWB. De Amsterdammer moet de ANWB ook een schadevergoeding van 75.000 euro betalen.

De man was makkelijk op te sporen, want in de mail die hij stuurde stond een link naar een echte betalingsherinnering. Daarop stonden zijn naam en lidmaatschapsnummer.

Maar elk nadeel heb zijn voordeel

“De onderwijsinstelling betaalde destijds in totaal 197.000 euro aan losgeld, dus er is sprake van zo'n 300.000 euro 'winst'.

Hoewel een simpele rekensom misschien de indruk wekt dat de universiteit er hiermee goed van af komt, stelt het zelf in interne communicatie dat dit nog steeds **'significant minder waard is dan de schade die de universiteit heeft geleden'.**”



Universiteit Maastricht maakt 'winst' na retour ransomware-crypto-losgeld

De Universiteit Maastricht heeft een deel van de cryptovaluta die het als losgeld voor een ransomwareaanval betaalde in 2019, teruggekregen dankzij politie en justitie. De universiteit betaalde destijds 197.000 euro aan crypto en krijgt nu 500.000 euro terug.

New Pas

- Click Other User
- Sign in with your username and password
- You will get the message to
- Your new password must
 - At least 15 characters
 - At least 1 capital letter
 - At least 1 number
 - At least 1 special character

Oplossingen

Wat je zelf kunt doen?

Iedereen kan al heel veel zelf doen door voorzichtig om te gaan met digitale systemen. Dit noemen we “**digitale hygiëne**”:

- Klik niet zomaar op links die je binnenkrijgt
- Laat je laptop of telefoon niet onbeheerd achter zonder deze te locken
- Wees kritisch op wat je verteld wordt, stel je niet open voor pretexting en phishing
- Gebruik goede wachtwoorden -> Hoe?
- Hergebruik je wachtwoorden niet
- Pas multi factor authenticatie toe
- Zorg dat je systemen up-to-date zijn en gebruik een virusscanner

Wachtwoordkraken

- Verschillende soorten aanvallen: **dictionary**, **brute force**, **rainbow**, **hybrid attack**
- Brute force attack: alle mogelijkheden afgaan, wordt moeilijker door gebruik van:
 - Hoofd- & kleine letters, getallen en alfanumerieke tekens (!, @, #, \$, %, ^, &)
 - Lange zinnen en/of acroniemen
 - Password Policy (history, lockout,...)



[NU.nl](http://nu.nl) > [Tech](#) > [Internet](#)



Betaalsysteem Keolis-bussen toegankelijk door wachtwoord '1234'

Gepubliceerd: 15 augustus 2018 11:56
Laatste update: 15 augustus 2018 12:36



Het systeem waarmee passagiers van ov-maatschappij Keolis in de bus een kaartje kunnen kopen, was eenvoudig toegankelijk doordat een programma op de betaalautomaten beveiligd was met het wachtwoord '1234'.

Wachtwoordsterkte

Bron: veiliginternetten.nl

Tekens	Aantal mogelijke combinaties	Brute force tijd
4	35.153.041	direct
5	2.706.784.157	direct
6	208.422.380.089	2 seconden
7	16.048.523.266.853	3 minuten
8	1.235.736.291.547.680	3 uur
9	95.151.694.449.171.400	2 weken
10	7.326.680.472.586.200.000	2 jaar
11	564.154.396.389.137.000.000	200 jaar
12	43.439.888.521.963.600.000.000	14 duizend jaar
13	3.344.871.416.191.200.000.000.000	1 miljoen jaar
14	257.555.099.046.722.000.000.000.000	82 miljoen jaar
15	19.831.742.626.597.600.000.000.000.000	6 miljard jaar
16	1.527.044.182.248.020.000.000.000.000.000	484 miljard jaar
17	117.582.402.033.097.000.000.000.000.000.000	37000 miljard jaar
18	9.053.844.956.548.480.000.000.000.000.000.000	3 miljoen miljard jaar

meestgebruikte wachtwoorden van 2020

(.nl-adressen)

- | | | |
|---------------|----------------|---------------|
| 1. 123456 | 18. computer | 35. 1qaz2wsx |
| 2. qwerty | 19. 1234567890 | 36.anaan |
| 3. 123456789 | 20. muziek | 37. pokemon |
| 4. welkom | 21. qwertyuiop | 38. 151526 |
| 5. 12345 | 22. hallo | 39. hallo123 |
| 6. wachtwoord | 23. rotterdam | 40. abc123 |
| 7. welkom01 | 24. 000000 | 41. 123qwe |
| 8. password | 25. willem | 42. familie |
| 9. 12345678 | 26. jemoeder | 43. qwerty123 |
| 10. 1234 | 27. Welkom01 | 44. rakker |
| 11. 7spu3 | 28. 111111 | 45. qazwsx |
| 12. welkom1 | 29. w8woord | 46. master |
| 13. amsterdam | 30. 1q2w3e4r | 47. jeroen |
| 14. feyenoord | 31. vergeten | 48. konijn |
| 15. 123123 | 32. mercedes | 49. internet |
| 16. lol123 | 33. hoihoi | 50. killer |
| 17. voetbal | 34. vakantie | |

Bovenstaande data is in november 2020 door Competa IT opgevraagd bij Scattered Secrets. Ten tijde van de realisatie van dit item stonden er 4.577.932.965 wachtwoorden in de database, waarvan 8.884.720 .nl-adressen.

Verschillende tekens

Het helpt wel om verschillende tekens te gebruiken:

- Van 12 cijfers: 1 seconde
- Naar 12 verschillende tekens: 226 jaar!

Maar zelfs dat is niet voldoende, gezien de ontwikkelingen. Daarom extra beveiliging door MFA.

TIME IT TAKES A HACKER TO BRUTE FORCE YOUR PASSWORD IN 2023					
Number of Characters	Numbers Only	Lowercase Letters	Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters, Symbols
4	Instantly	Instantly	Instantly	Instantly	Instantly
5	Instantly	Instantly	Instantly	Instantly	Instantly
6	Instantly	Instantly	Instantly	Instantly	Instantly
7	Instantly	Instantly	1 sec	2 secs	4 secs
8	Instantly	Instantly	28 secs	2 mins	5 mins
9	Instantly	3 secs	24 mins	2 hours	6 hours
10	Instantly	1 min	21 hours	5 days	2 weeks
11	Instantly	32 mins	1 month	10 months	3 years
12	1 sec	14 hours	6 years	53 years	226 years
13	5 secs	2 weeks	332 years	3k years	15k years
14	52 secs	1 year	17k years	202k years	1m years
15	9 mins	27 years	898k years	12m years	77m years
16	1 hour	713 years	46m years	779m years	5bn years
17	14 hours	18k years	2bn years	48bn years	380bn years
18	6 days	481k years	126bn years	2tn years	26tn years

Multi factor authenticatie: MFA

Wat je weet:

- Account met een een sterk **wachtwoord**

Wat je hebt, meestal in de vorm van token:

- Een **hardwaretoken** (bijvoorbeeld RSA secureID, Yubikey)
- Een **softwaretoken** (bijvoorbeeld Google of Microsoft Authenticator)

Wat je bent:

- Een **biometrischetoken** (gezichtherkenning, vingerafdruk, stem, ...)



De meest veilige aanpak is alle drie toe te passen. Worden er twee toegepast dan noemen we het ook **Two Factor Authentication (2FA)**

Oefening CSC5.2: Voeg MFA toe

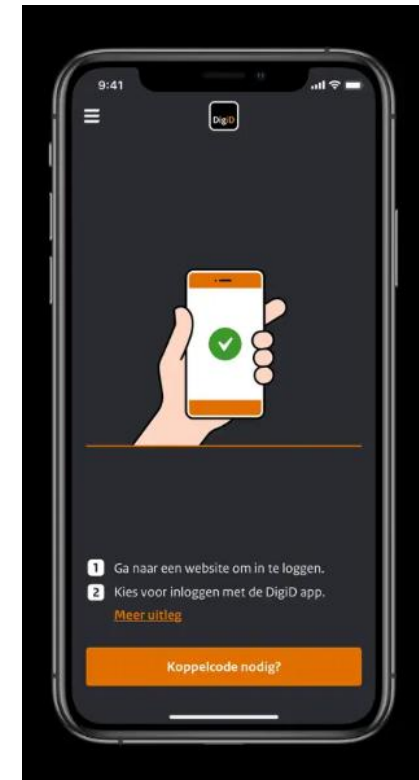
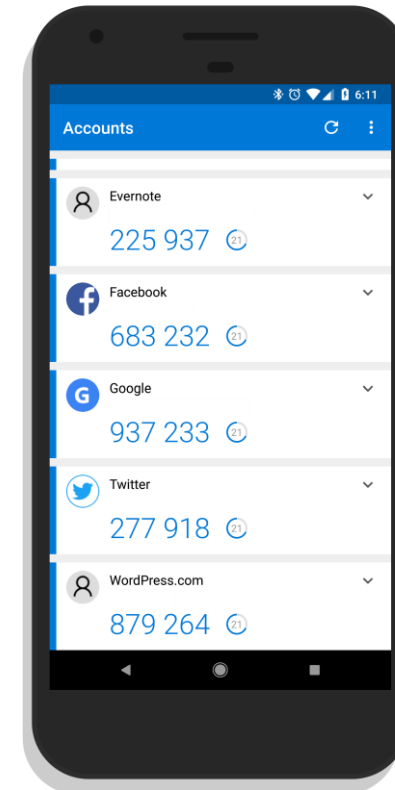
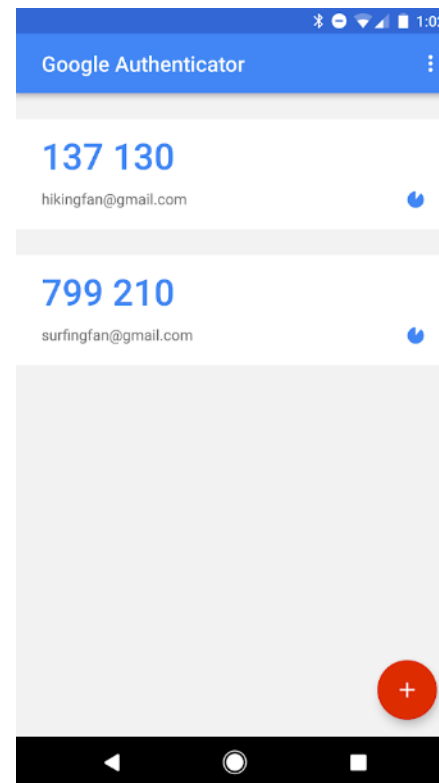
Oefening CSC5.2: Voeg MFA toe

Vragen:

- Wie gebruikt er al MFA?
- Wat voor MFA gebruik je?

Opdracht:

- Voeg MFA toe aan een account dat je al hebt, op basis van Google Authenticator, Microsoft Authenticator of een andere Authenticator app als je er al ervaring mee hebt.
- Log daar eens mee in. Is het optioneel of verplicht?
- Daarnaast kunnen we kijken naar <https://edu.nl/t43vn> (wat gebruik je zelf).



Wat kan de CSC-er doen?

Elke CSC-er houdt zich bezig met de beveiliging van de infrastructuur (netwerken en systemen), onder andere:

- Up-to-date houden van alle gebruikte software
- Toepassing van technische beveiligingsapparaten (*malware scanners, firewalls,*)
- Toepassen van encryptie (dit beschermt zowel de vertrouwelijkheid als de integriteit)
- Systemen beschikbaar houden en beschermen tegen (D)DoS aanvallen



Wat kan de CyberSecurity expert doen?

Een CyberSecurity expert houdt zich daarnaast mogelijk bezig met:

- *Ethical hacking*: hacker-technieken inzetten om te testen hoe makkelijk de beveiliging te omzeilen is met het oog op verbeteren van die beveiliging
- *Ontwerp* van bij voorbaat zo veilig mogelijke infrastructuur voordat deze gebouwd of aangepast wordt
- *Adviseren* van zowel de niet-technische mensen in een organisatie als software-ontwikkelaars ten aanzien van beveiliging



Malware scanners

Apparaten in het netwerk die uiteenlopende typen malware kunnen herkennen en desgewenst tegenhouden:

Virusscanners

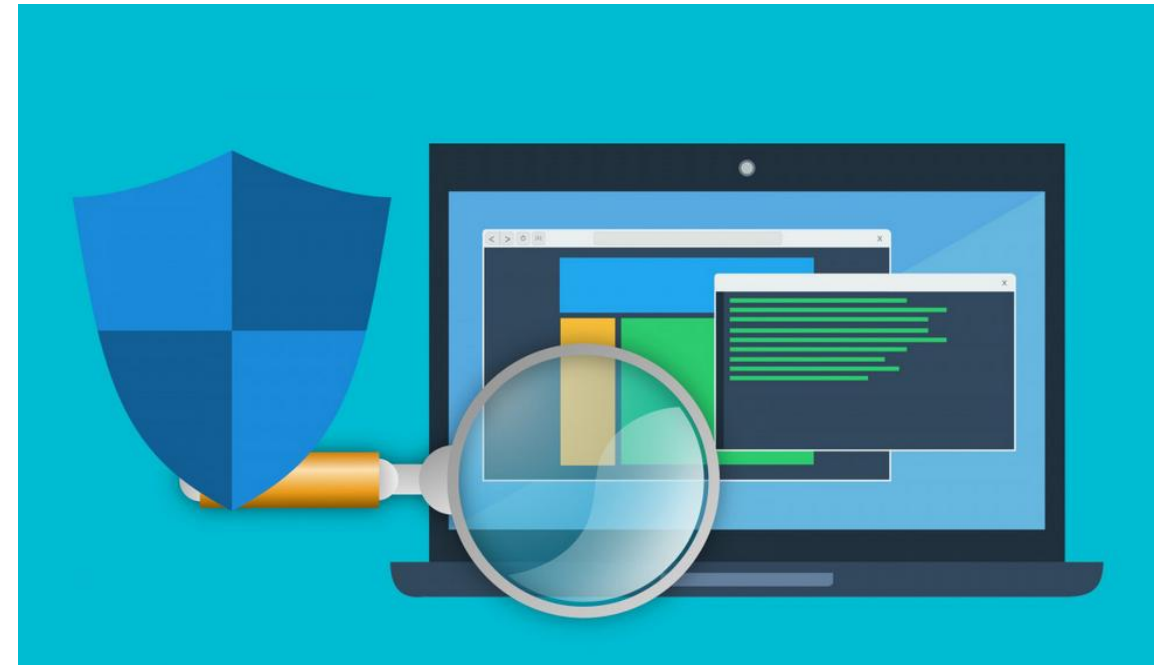
- Zowel voor het hele netwerk als op individuele systemen in het netwerk

Intrusion detection systems (IDS)

- Nemen waar dat er iets ongewensts op het netwerk gebeurt maar houden het niet tegen

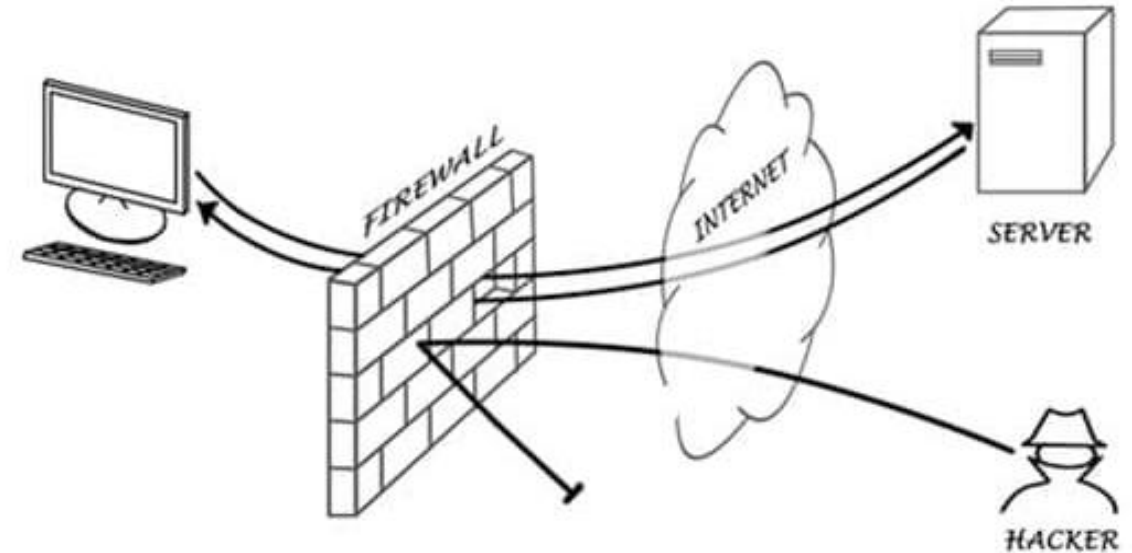
Intrusion prevention systems (IPS)

- Als IDS maar houden de bedreiging tegen



Firewall

- Een **firewall** is een netwerkbeveiligingsapparaat dat actief netwerkverkeer monitort en filtert zowel inkomend als uitgaand verkeer.
- De **firewall** fungeert als een beschermende barrière tussen een privé-interne netwerk en het openbare internet.
- Het primaire doel van een **firewall** is om onschadelijk verkeer door te laten terwijl potentieel schadelijk verkeer wordt geblokkeerd om het netwerk binnen te komen.



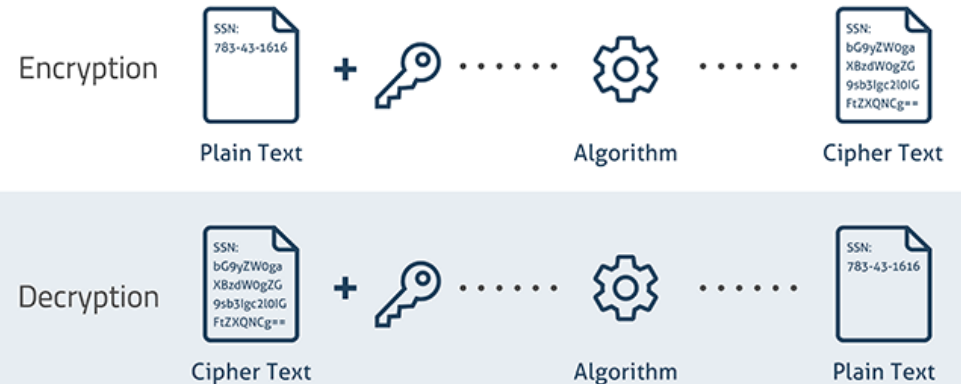
Encryptie

Encryptie is een computerverwerking die platte tekst/leesbare tekst (ongecodeerde, menselijk leesbare gegevens) codeert tot **ciphertext** (gecodeerde gegevens).

Deze **Ciphertext** is alleen toegankelijk voor geautoriseerde gebruikers met de juiste cryptografische sleutel.

Encryptie zet leesbare gegevens om in een andere vorm die alleen mensen met het juiste wachtwoord kunnen **decoderen** en bekijken

SAMPLE ENCRYPTION AND DECRYPTION PROCESS



Nog niet
gemaakt!

Oefening CSC5.3

Beoordeel een artikel a.d.h.v. de presentatie

Oefening CSC5.3

Beoordeel een artikel a.d.h.v. de presentatie

Er zijn veel artikelen beschikbaar op internet over security, het gebrek ervan en de consequenties. Nu ga je dit zelf onderzoeken.

- Kies een artikel uit. Bronnen hiervoor zijn bijvoorbeeld Tweakers.net, Computable.nl of nos.nl
- Neem een artikel waar je zelf iets mee hebt, misschien omdat een bekende daar werkt, of omdat je er zelf last van hebt gehad

Beantwoord daarbij de volgende vragen en lever dit als document (ongeveer 2xa4) in:

- Wat is de bron van je artikel?
- Waarom heb je voor dit artikel gekozen?
- Over welk(e) security onderwerp(en) gaat het, wat was de bedreiging?
- Bekijk het artikel goed en reflecteer hierop via de indeling van CIA/BIV
- Wat was de consequentie?
- Beschrijf wat (een) mogelijke oplossingen zouden zijn.





HIER KOMT ALLES SAMEN